

Sistema PFC:

AUTENTICAÇÃO SEGURA COM 2FA E LGPD

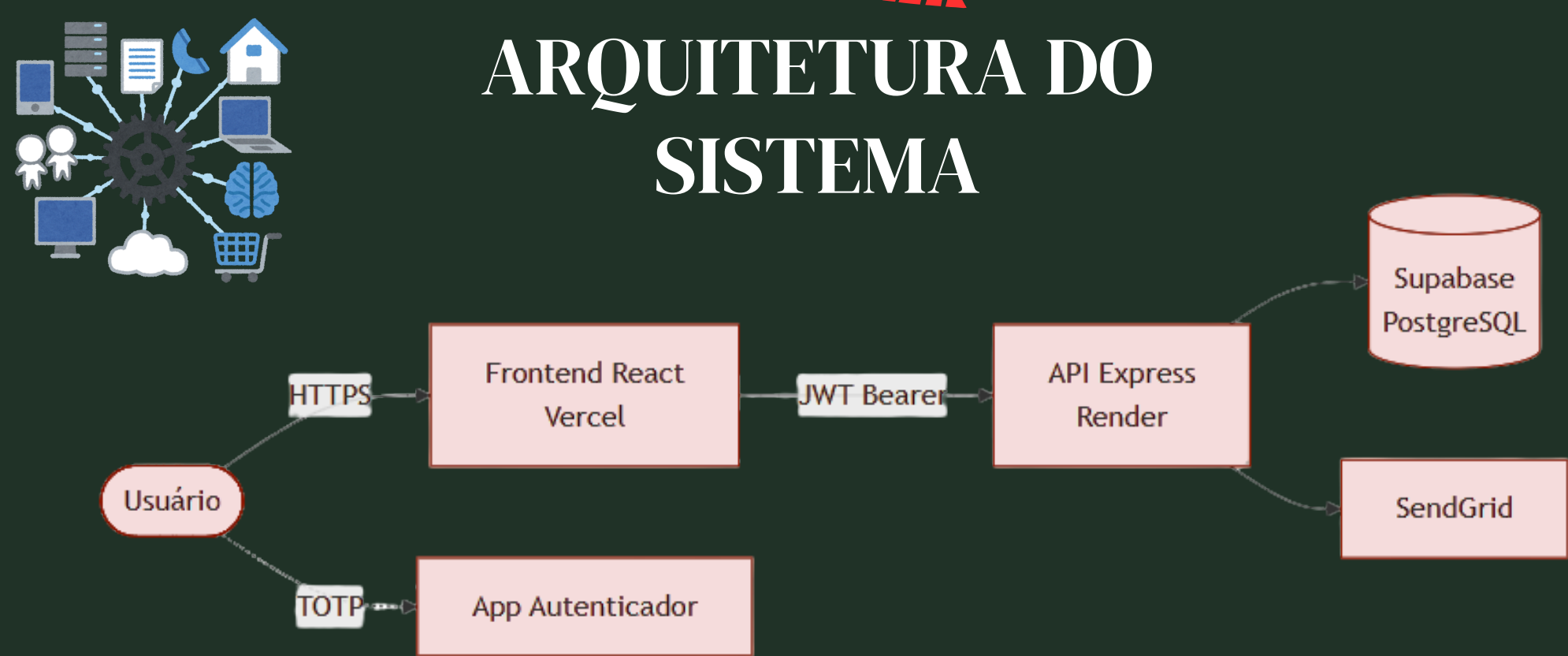
GABRIEL ANTÔNIO VIEIRA CORDEIRO - GUSTAVO IWAI FUJIMOTO - JOÃO HENRIQUE RODRIGUES BATISTA - JULIANA FERREIRA ZANELATO - PEDRO HENRIQUE SANTOS DE ANDRADE

UNIVERSIDADE DE MOGI DAS CRUZES, MOGI DAS CRUZES, SP, BRASIL

INTRODUÇÃO

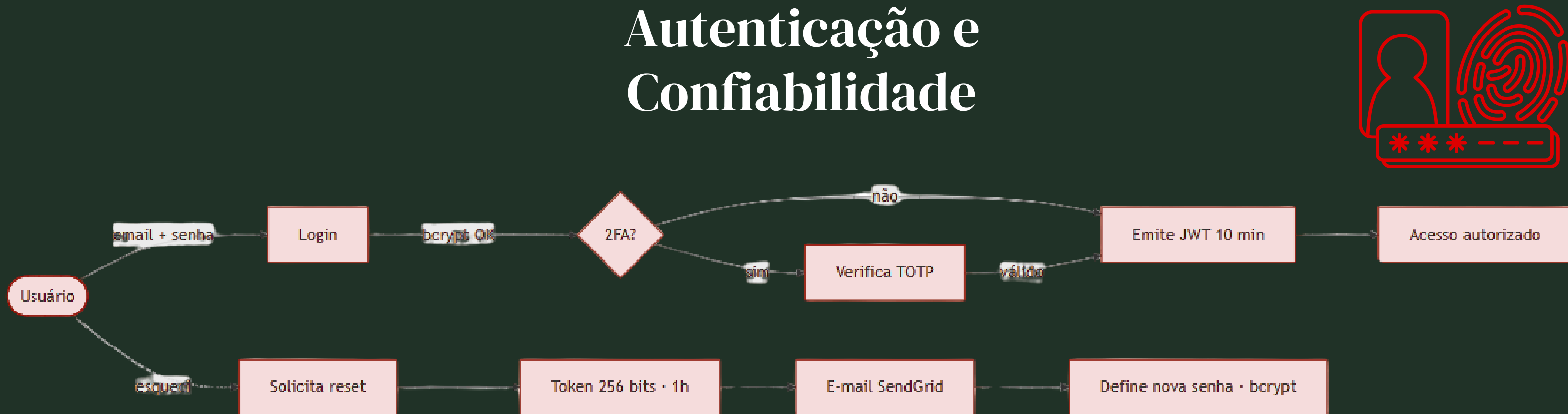
Aplicação web full-stack desenvolvida com React, Node.js/Express e Supabase, focada em autenticação segura e proteção de dados. O sistema implementa cadastro com consentimento conforme a LGPD, login com autenticação em dois fatores (2FA) via TOTP, redefinição de senha utilizando tokens criptográficos e auditoria completa de eventos de segurança. A solução foi projetada para garantir confidencialidade, integridade e rastreabilidade das informações dos usuários, aplicando boas práticas modernas de cibersegurança e governança de dados.

ARQUITETURA DO SISTEMA



Arquitetura em camadas: React (front-end), Express modular (API) e Supabase (banco de dados).
Estrutura modular por funcionalidades: auth, user, consent, audit e email.
Deploy distribuído com Vercel, Render e Supabase gerenciado.

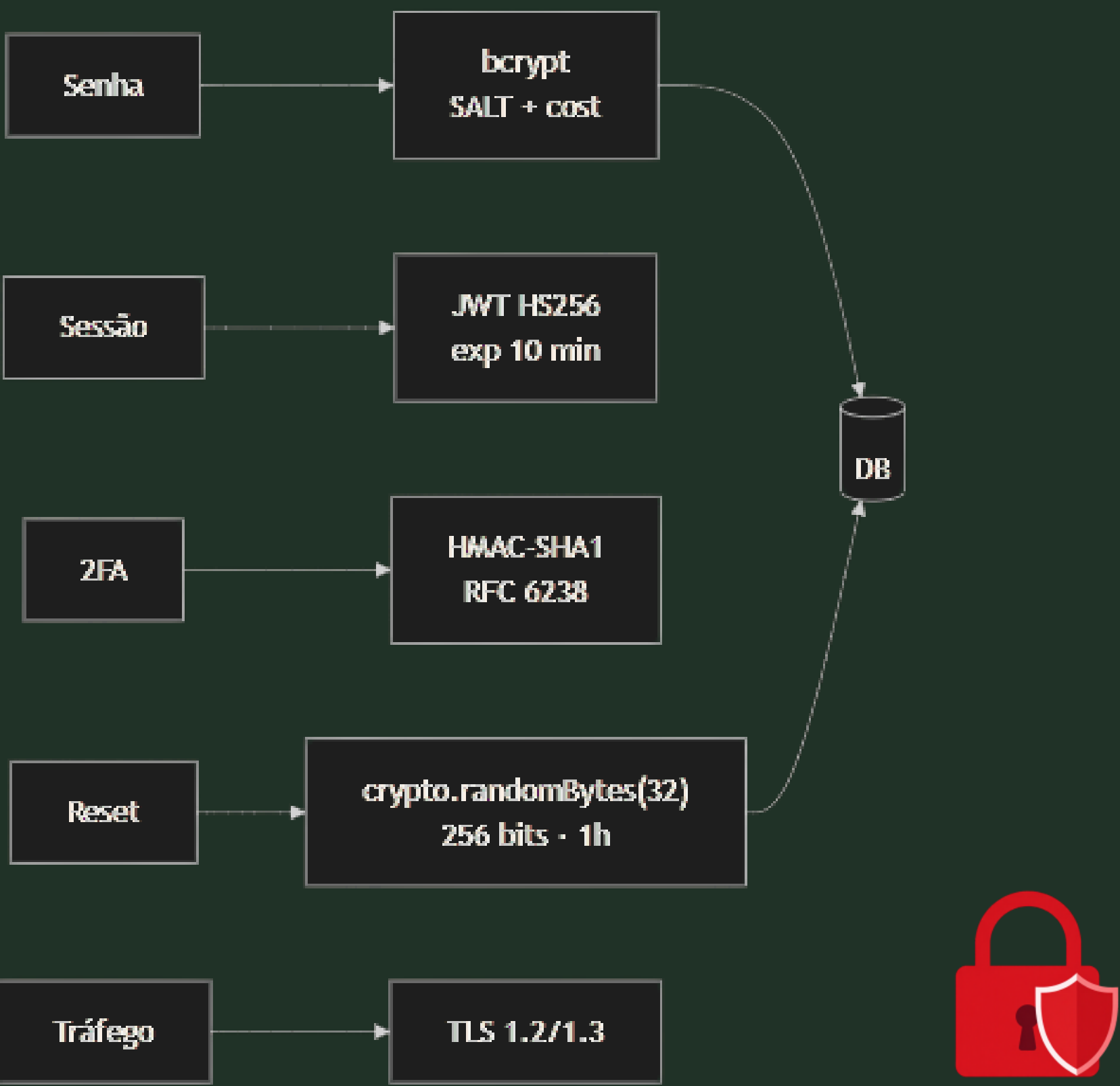
Autenticação e Confiabilidade



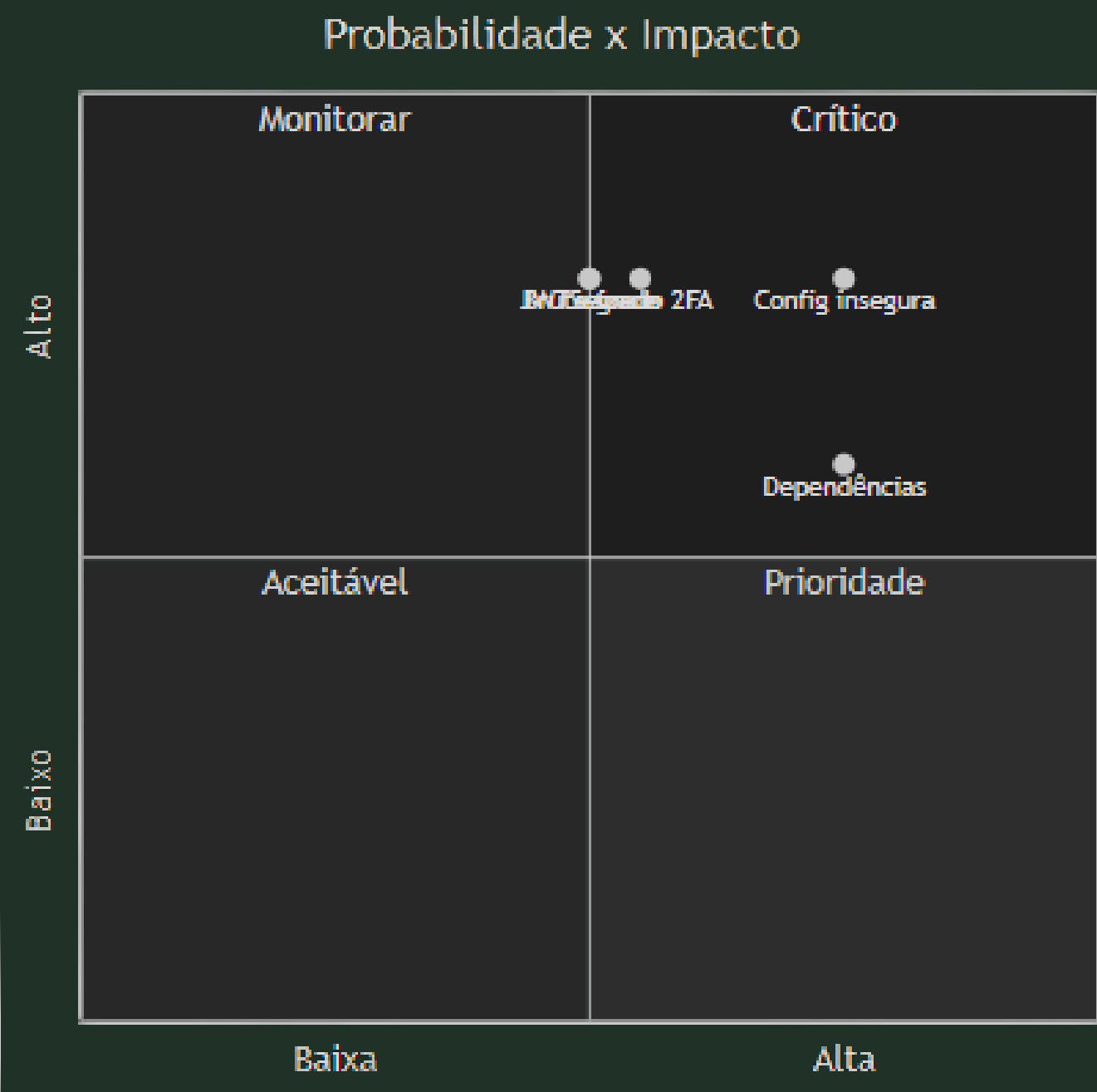
- Senhas protegidas com bcrypt utilizando salt único e custo adaptativo.
- Autenticação em dois fatores (2FA TOTP) compatível com Google Authenticator e Authy.
- Bloqueio automático de acesso após 5 tentativas inválidas por 15 minutos.

CRIPTOGRAFIA

Item	Algoritmo	Tamanho
Senha	bcrypt	salt 128 bits · cost ≥ 10
JWT	HMAC-SHA256	exp 10 min
2FA	TOTP / HMAC-SHA1	segredo 160 bits · janela 30 s
Reset	CSPRNG	256 bits · validade 1 h
Transporte	TLS	1.2 / 1.3



ANÁLISE DE RISCOS

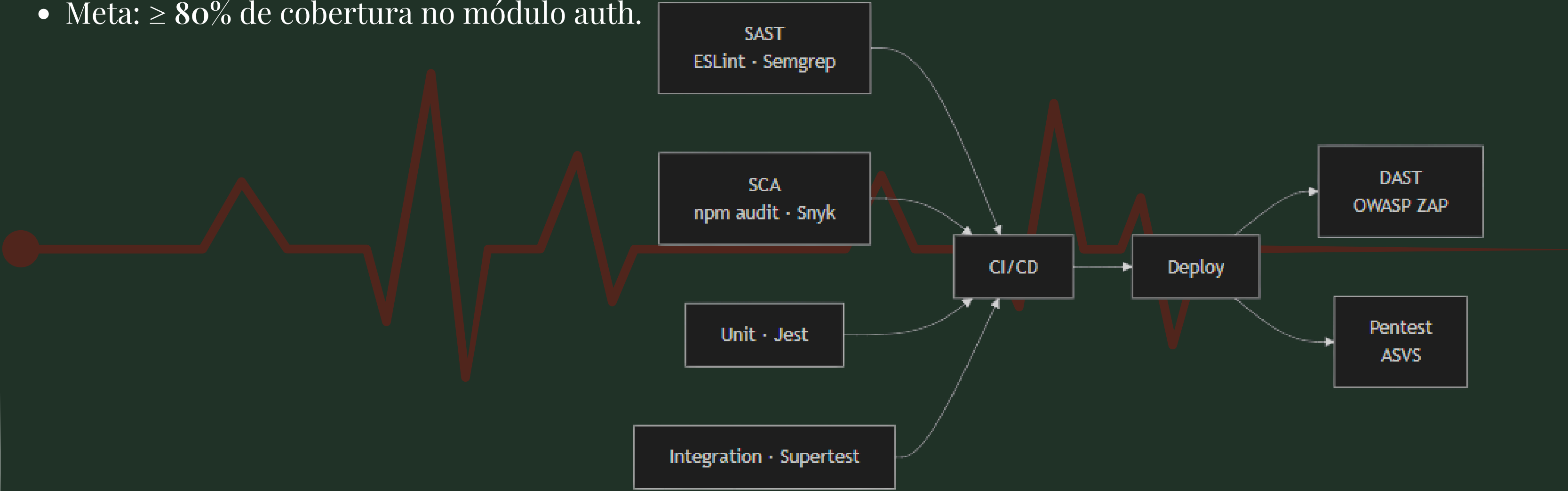


- Top 5 riscos tratados:
1. Brute force $\Rightarrow$ rate limit + bloqueio de conta.
 2. Sequestro de JWT $\Rightarrow$ expiração curta (10 min) + HTTPS + CORS.
 3. User enumeration $\Rightarrow$ mensagens genéricas.
 4. LGPD $\Rightarrow$ consentimento obrigatório + auditoria.
 5. Reset de senha $\Rightarrow$ token de 256 bits, uso único, expira em 1 h.



ANÁLISE DE RISCOS

- Cobertura:
- 36 casos de teste mapeados (login, 2FA, cadastro, reset, JWT, auditoria).
 - Critério: o vulnerabilidades High no npm audit e no OWASP ZAP.
 - Meta: $\geq 80\%$ de cobertura no módulo auth.



CONCLUSÃO

O sistema desenvolvido demonstrou que a integração de autenticação segura, criptografia e conformidade com a LGPD pode ser aplicada de forma eficiente em aplicações web modernas. A utilização de 2FA, proteção contra ataques e auditoria de eventos reforçou a confiabilidade da solução, garantindo maior segurança, integridade e privacidade dos dados dos usuários.

VISITE NOSSO REPOSITÓRIO

